

Echtzeit-Datenverarbeitung

Cyber-Security

Sichere Software Entwicklung

Prof. Dr. Henning Trsek

Technische Hochschule Ostwestfalen-Lippe

Fachbereich Elektrotechnik und Technische Informatik

inIT - Institut für industrielle Informationstechnik

henning.trsek@th-owl.de



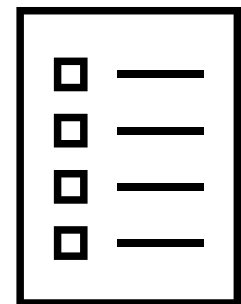
Agenda

- ▶ Teil 1: Überblick technische Kernelemente der SW-Entwicklung
- ▶ Teil 2: Solarwinds Orion - Ein Angriff von herausragender Bedeutung
- ▶ Teil 3: Sichere SW-Entwicklung nach Standard IEC 62443-4-1 am Beispiel des o.g. Angriffs

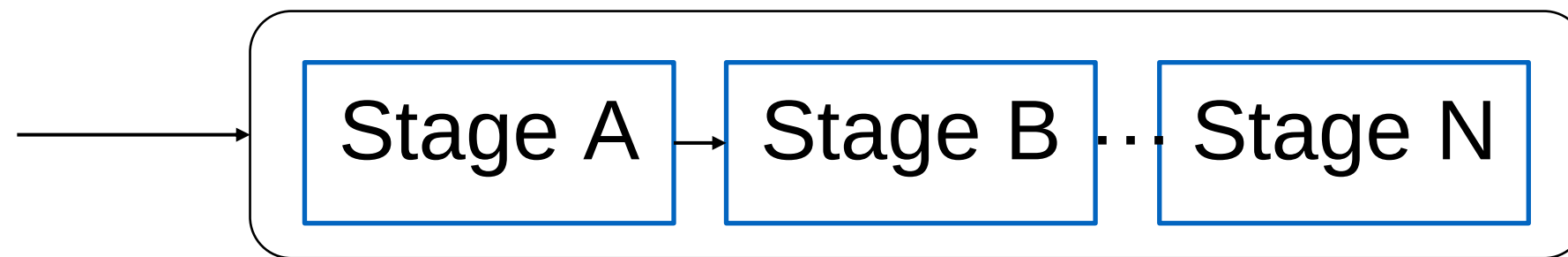
Teil 1: Kernelemente der Softwareentwicklung

- ▶ Wie kommt mein Feature von meinem Schreibtisch zum Kunden?

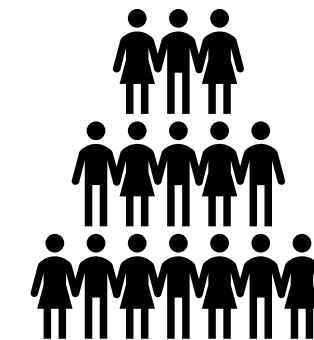
Anforderungen



Das Produkt
erzeugen



Der Weg zum
Kunden



1. Anforderungen: Vom Kunden benötigte Features

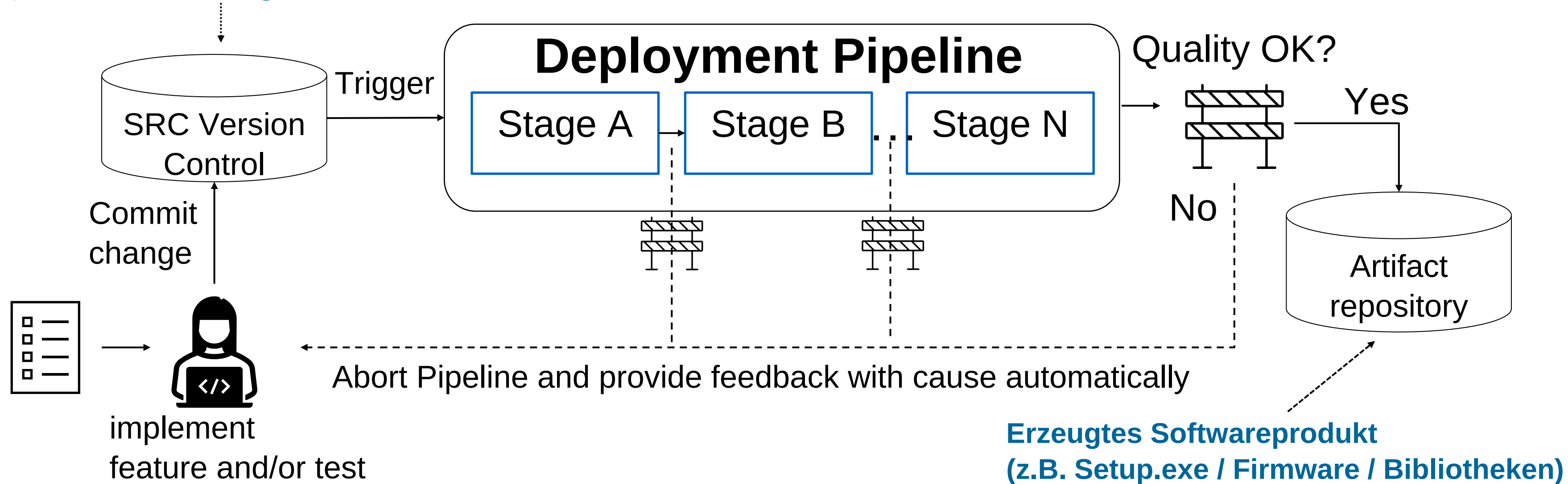


Akteure:

Kunden, Vertrieb, Produktmanagement (PM), Produkt Owner (PO), Entwickler

Schritt 2: Deployment Pipeline - Feedback so früh wie möglich

Quellcode / Konfigurationsdateien

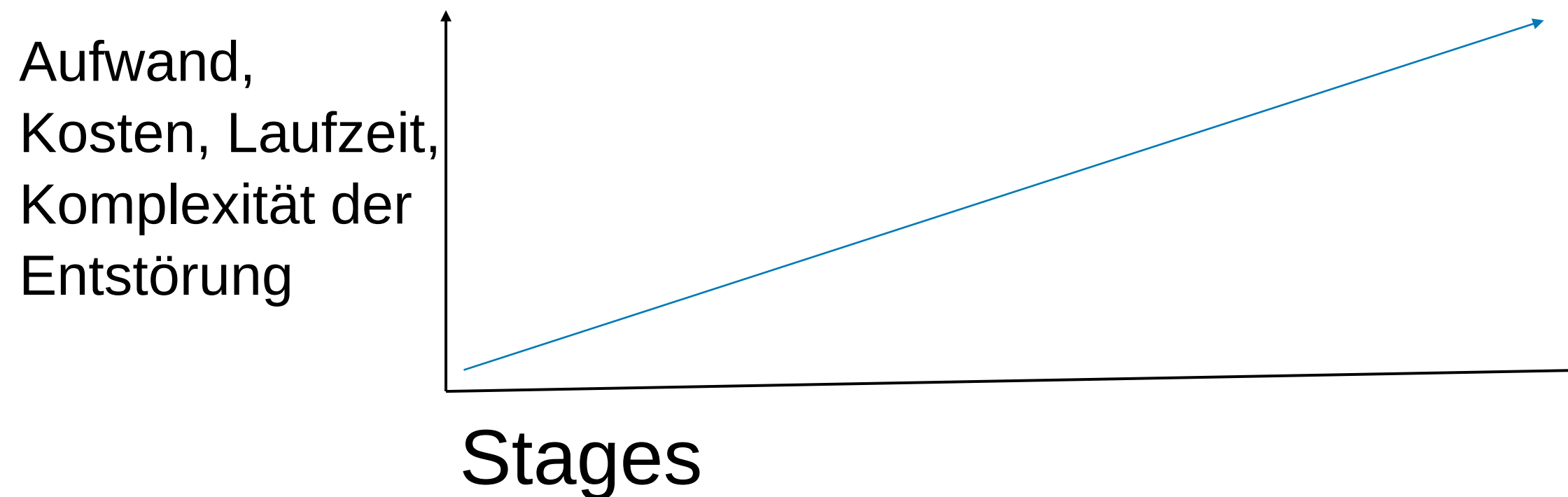
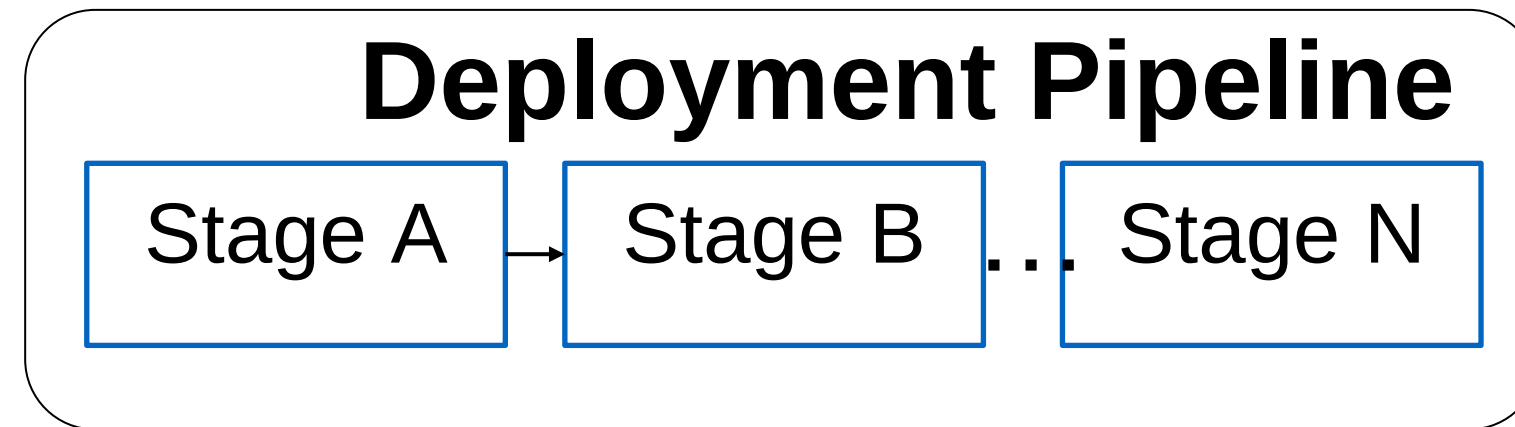


Weitere Details zum Konzept „Deployment Pipeline“ unter:

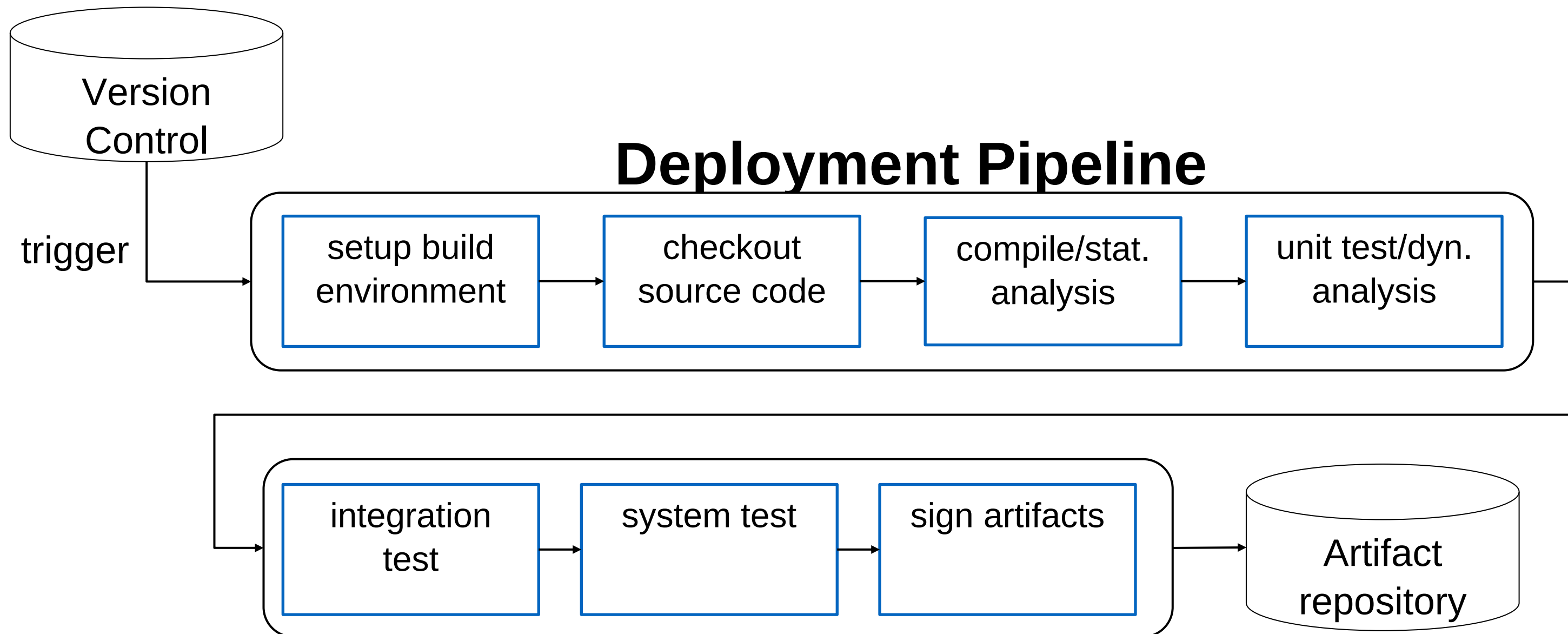
Accelerate: The Science Behind Devops: Building and Scaling High Performing Technology Organizations, Forsgren, Humble, 2018,

<https://continuousdelivery.com/> , <https://martinfowler.com/articles/continuousIntegration.html> , <https://aws.amazon.com/de/devops/continuous-delivery/>

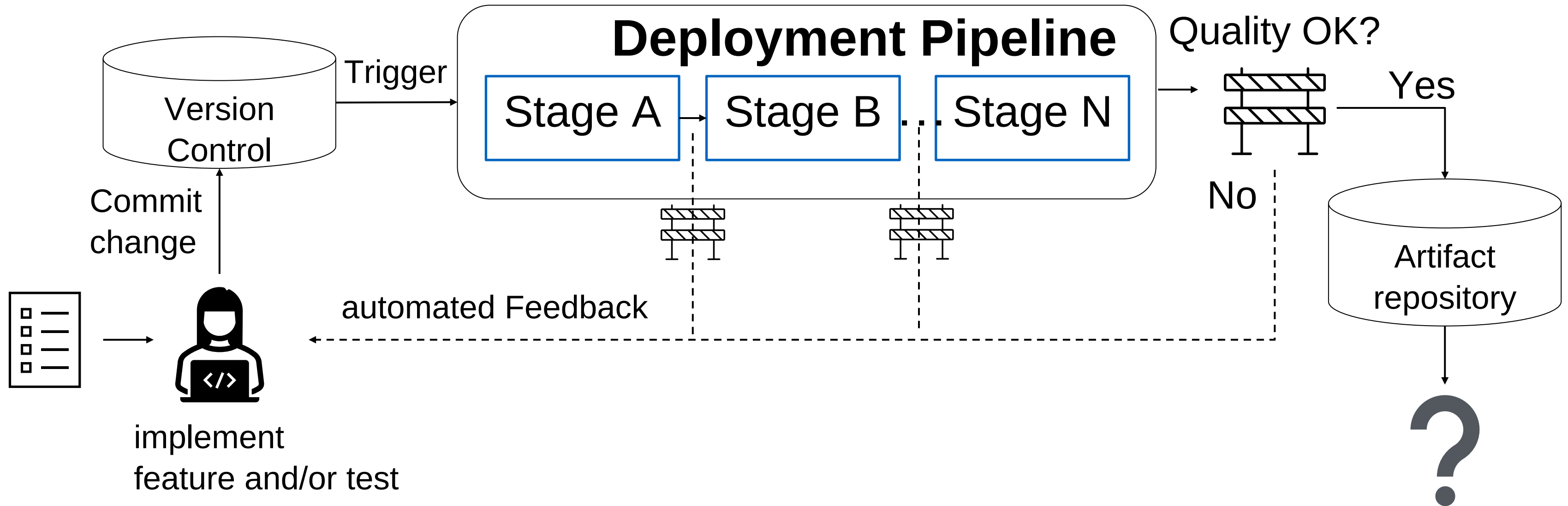
Schritt 2: Deployment Pipeline - Bugs früh beheben



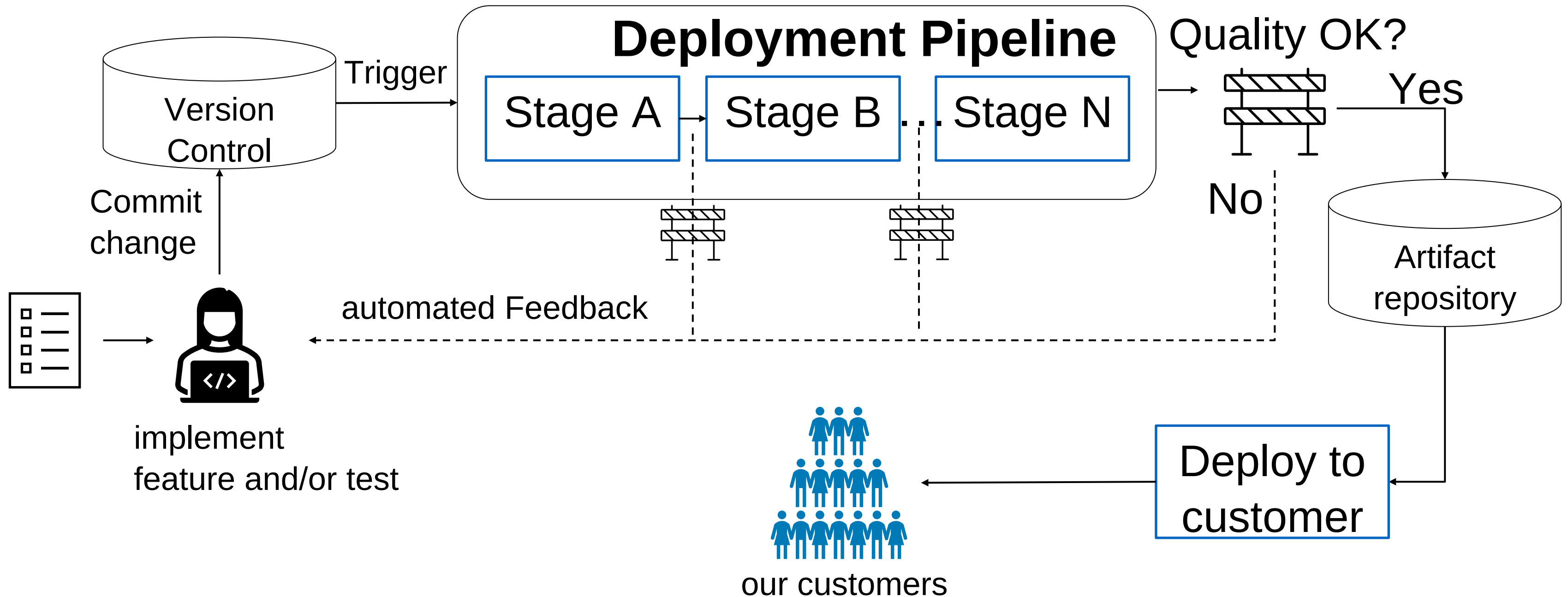
Schritt 2: Deployment Pipeline - Die Stages im Detail (Beispiel)



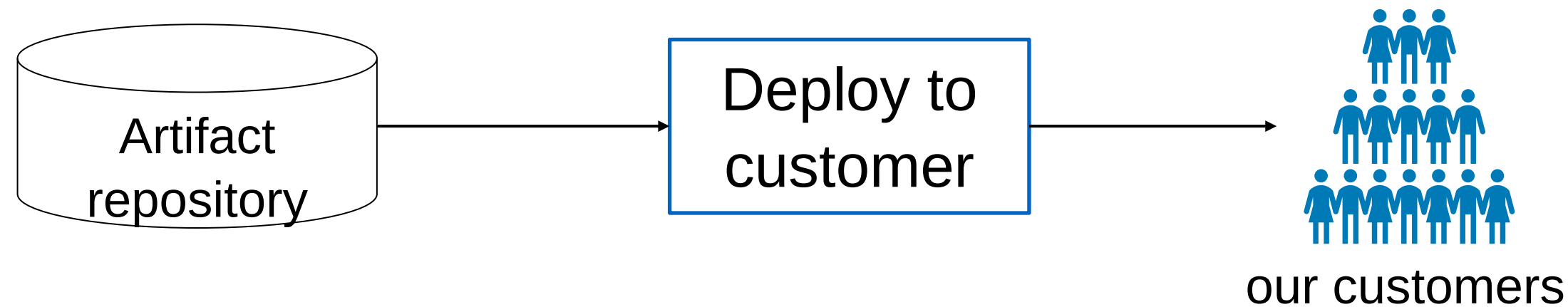
Schritt 2: Deployment Pipeline - Wann sind wir fertig?



Schritt 2: Deployment Pipeline - Produkt erfolgreich geliefert



Schritt 3: Wie kommt das Produkt zum Kunden?



- ▶ Wie kommt die Software für Industriekomponenten zum Kunden?

Beispiele:

- ▶ Fertigung des Produktes mit neuer Firmware
- ▶ Download von der Herstellerwebseite
- ▶ Download durch Engineering Software

Zusammenfassung Teil 1 – Kernelemente der SW-Entwicklung

- ▶ Jeder SW-Entwicklungsprozess beschäftigt mit mindestens 3 Punkten:
 - ▶ Der Anforderungserhebung
 - ▶ Der Deploymentpipeline
 - ▶ Dem Weg des Produkts zum Kunden
- ▶ Die Deploymentpipeline ist der technische Kern eines Entwicklungsprozesses
- ▶ Die Deploymentpipeline unterstützt die wesentlichen Schritte der SW-Entwicklung vom EntwicklerInnen-PC bis zum Kunden
- ▶ Sie ist unabhängig vom Vorgehensmodell der SW-Entwicklung
- ▶ Sie wird typischerweise in Ausprägung und Automatisierungsgrad auf das Vorgehensmodell und das Unternehmen angepasst

Supply Chain Attack – was ist das?

- ▶ „**Supply chain attacks** are an emerging kind of threat that target software developers and suppliers. The goal is to access source codes, build processes, or update mechanisms by infecting legitimate apps to distribute malware.“
- ▶ **Types of supply chain attacks**
 - ▶ Compromised software building tools or updated infrastructure
 - ▶ Stolen code-sign certificates or signed malicious apps using the identity of dev company
 - ▶ Compromised specialized code shipped into hardware or firmware components
 - ▶ Pre-installed malware on devices (cameras, USB, phones, etc.)

Quelle: <https://docs.microsoft.com/en-us/microsoft-365/security/intelligence/supply-chain-malware?view=o365-worldwide>

Teil 2: Ein Angriff von besonderer Bedeutung

SOLARWINDS-HACK

Massiver Cyberangriff

Bel...

SolarWinds-Hack

SolarWinds-Hack

Der Spior

Experten spreche
Tausender US-B
Betroffene.

Von Patrick Beu
18.12.2020, 18.

Kompromittierte Software auch in vielen deutschen Behörden im Einsatz

Der SolarWinds-Hack gilt als historisch, die USA vermuten russische Urheber dahinter. Nun wird klar: Auch deutsche Behörden wie das BKA und der zentrale IT-Dienstleister des Bundes haben die manipulierte Software genutzt.

Von **Marcel Rosenbach**

06.01.2021, 14.42 Uhr

Eine gigantische Spionageoperation im Auftrag der Atomwaffenbehörde der USA, amerikanische Behörden und Unternehmen verschaffte sich Zugriff auf die Daten von zahlreichen deutschen Behörden haben die kompromittierte Software eingesetzt.

Quellen:

<https://msrc-blog.microsoft.com/2021/02/18/microsoft-internal-solorigate-investigation-final-update/>

<https://www.spiegel.de/netzwelt/netzpolitik/solarwinds-hack-der-spionagefall-des-jahres-a-0b728cc4-d375-4cb9-9450-3635ca8172a0>

<https://www.spiegel.de/netzwelt/netzpolitik/solarwinds-hack-kompromittierte-software-auch-in-vielen-deutschen-behoerden-im-einsatz-a-2890f2fb-4422-40d2-b9eb-a1dcfe30e64d>

<https://www.faz.net/aktuell/wirtschaft/digitec/solarwinds-hack-massiver-cyberangriff-gefaehrdet-deutsche-behoerden-17134477.html>

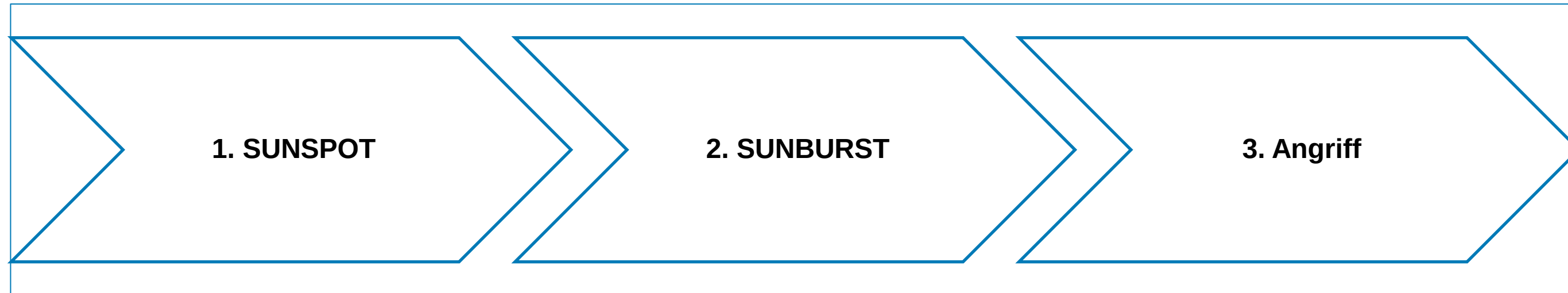
1
las
tes
h
ns
1.

Case Study: Solarwinds Orion Compromise 2020

- ▶ Solarwinds Orion: Software für Netzwerküberwachung / IP Adressverwaltung
- ▶ Ziel/potentielle Opfer: >18000 Unternehmen und Behörden weltweit / bis zu 300 in Deutschland*
- ▶ Art des Angriffs: Supply Chain Angriff über den Build und Deployment Prozess der Software Solarwinds Orion
- ▶ Ziel des Angriffs: Malware bei Solarwinds Kunden installieren, Angriffe auf die Kunden
- ▶ Weitere Bezeichnungen des Vorfalls: Sunburst / Dark Halo / Solorigate
- ▶ Mutmaßliche Angreifer: APT29, zugeschrieben dem russischen Auslandsgeheimdienst SVR (vgl. 2016 US DNC intrusion)

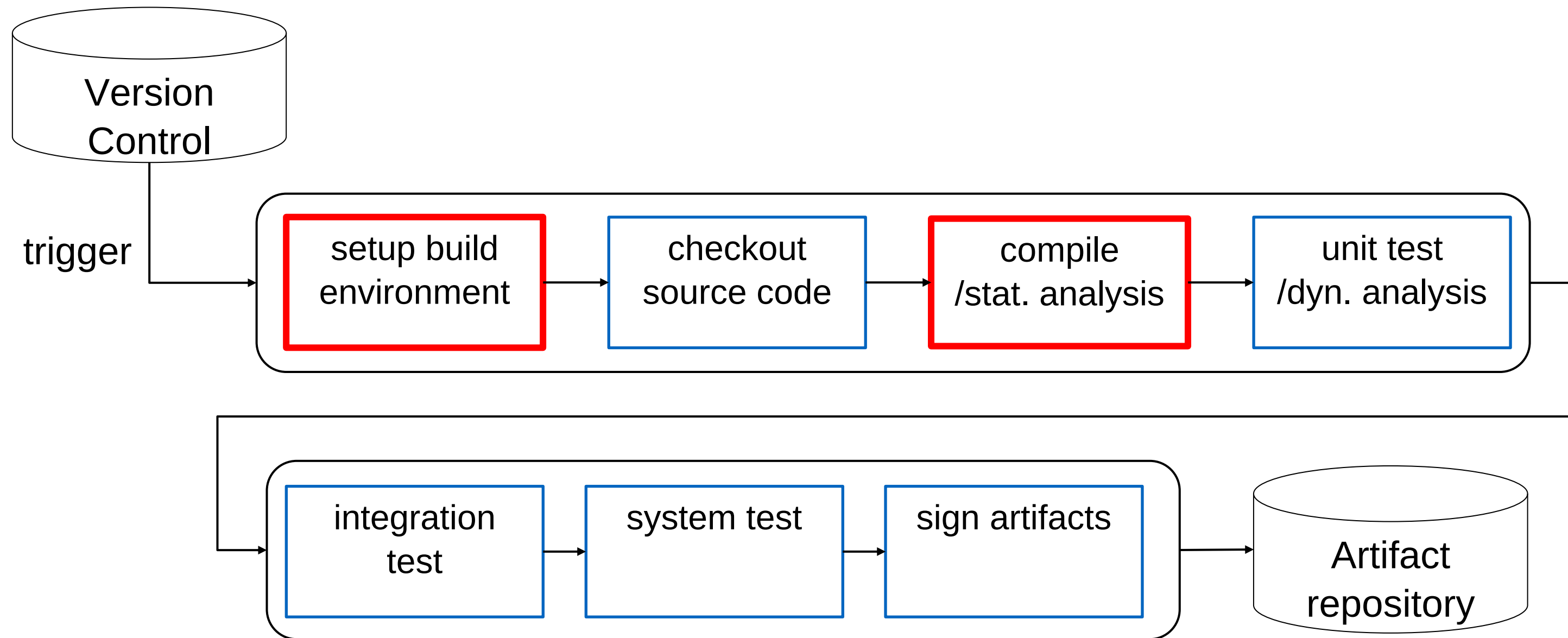
Quellen: <https://www.cisa.gov/uscrt/ncas/alerts/aa20-352a> ,
<https://www.crowdstrike.com/blog/bears-midst-intrusion-democratic-national-committee/>
<https://www.whitehouse.gov/briefing-room/statements-releases/2021/04/15/fact-sheet-imposing-costs-for-harmful-foreign-activities-by-the-russian-government/>
<https://www.cisa.gov/news/2021/01/05/joint-statement-federal-bureau-investigation-fbi-cybersecurity-and-infrastructure>
<https://www.spiegel.de/netzwelt/netzpolitik/solarwinds-300-stellen-in-deutschland-durch-hackerangriffe-gefaehrdet-a-0e8e3327-6079-4668-ac6e-cc86a274215c>

Solarwinds Orion – der 3 stufige Angriff



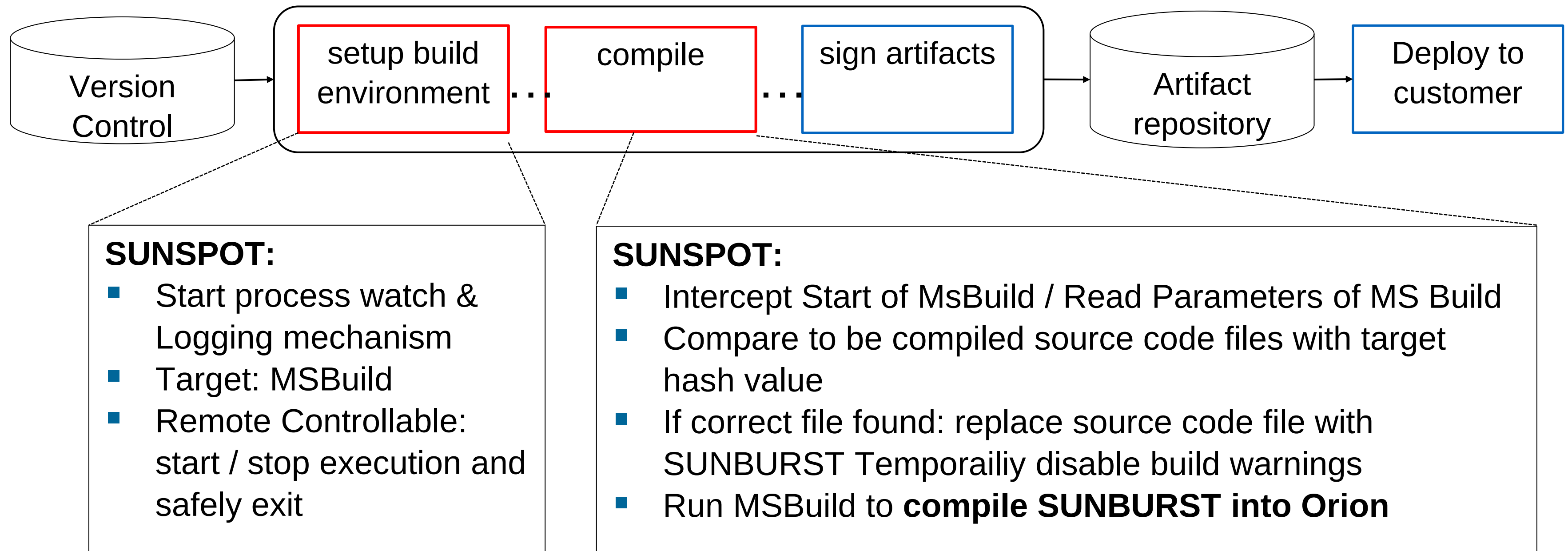
- Bei Solarwinds
 - Angriff auf Solarwinds Deployment Pipeline
 - Integriert Sunburst Backdoor in Solarwinds Orion Software
- Bei Orion Kunden
 - Minimale Custom-Backdoor
 - Inventarisiert infizierte Systeme und Umgebungen
 - Meldet Funde an Command & Control System
 - Triggert Schritt 3 wenn Ziel in Profil passt
- Bei Orion Kunden
 - Nachladen von z.B. Cobalt Strike via eigenem TEARDROP Loader
 - Gezielter, manueller Angriff auf Kundensystem „Hands on Keyboard“

Stufe 1 – SUNSPOT im Detail - betroffene Stages Deployment PI



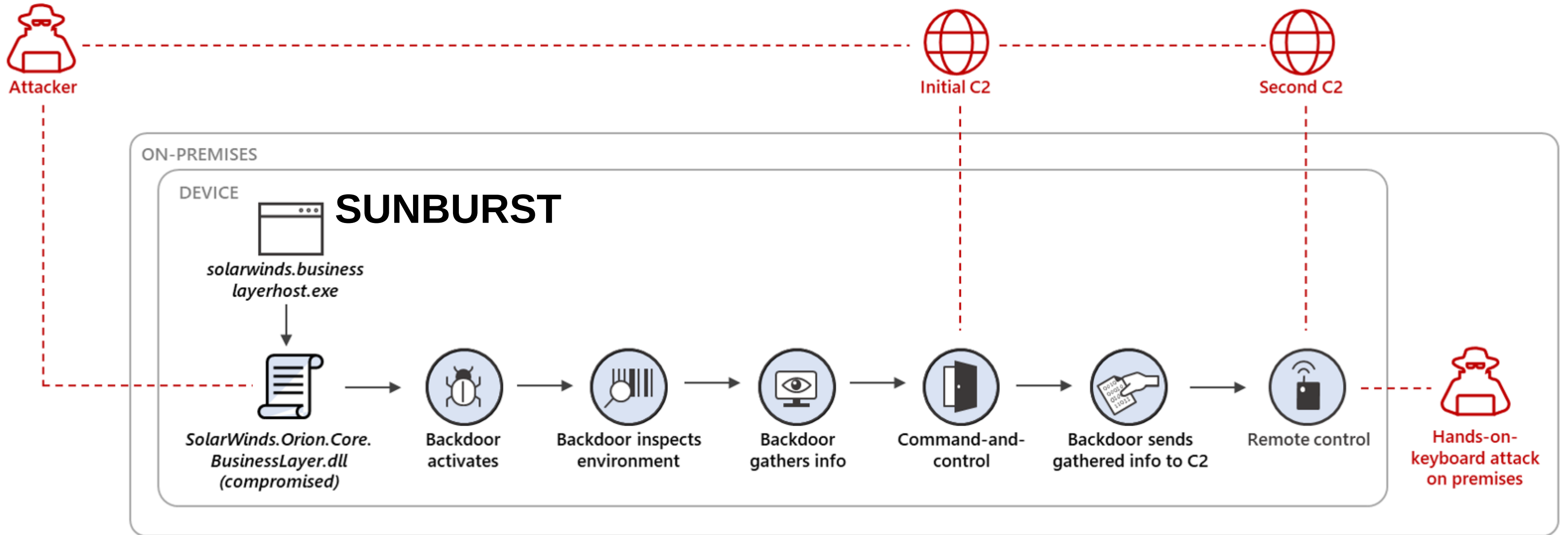
Stufe 1 – SUNSPOT im Detail

How was the attack at the Solarwinds Deployment Pipeline carried out?



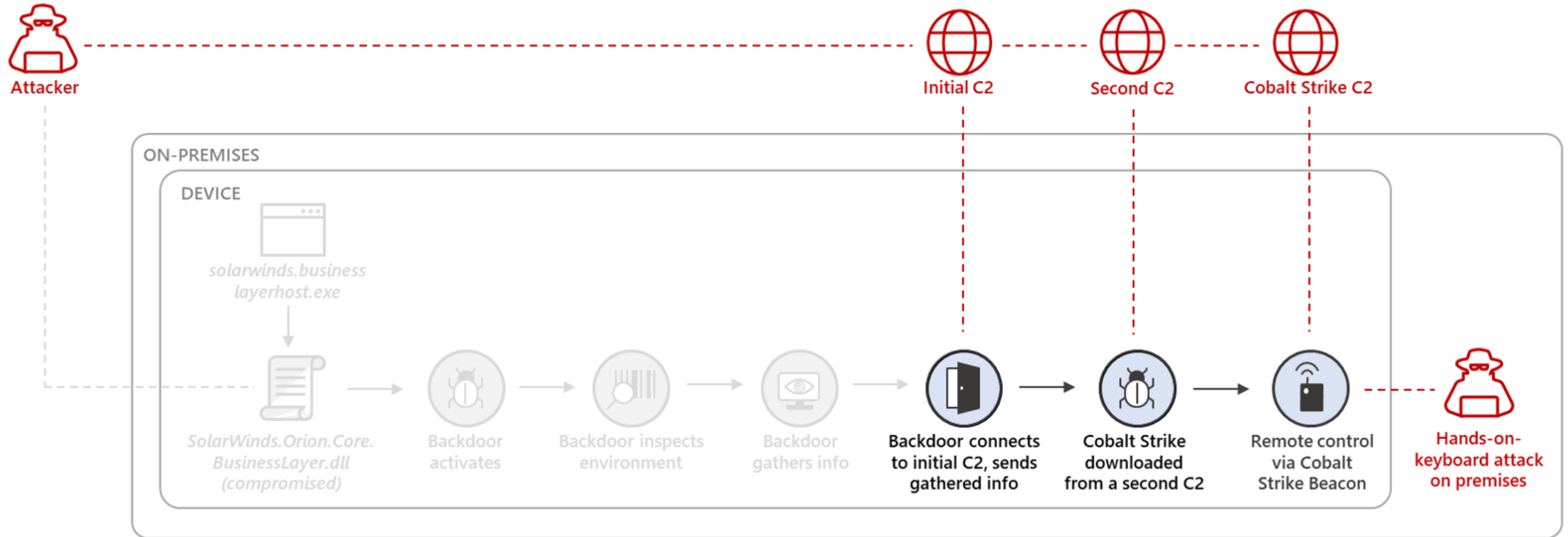
Quelle: <https://www.crowdstrike.com/blog/sunspot-malware-technical-analysis/>

Stufe 2 & 3 im Detail



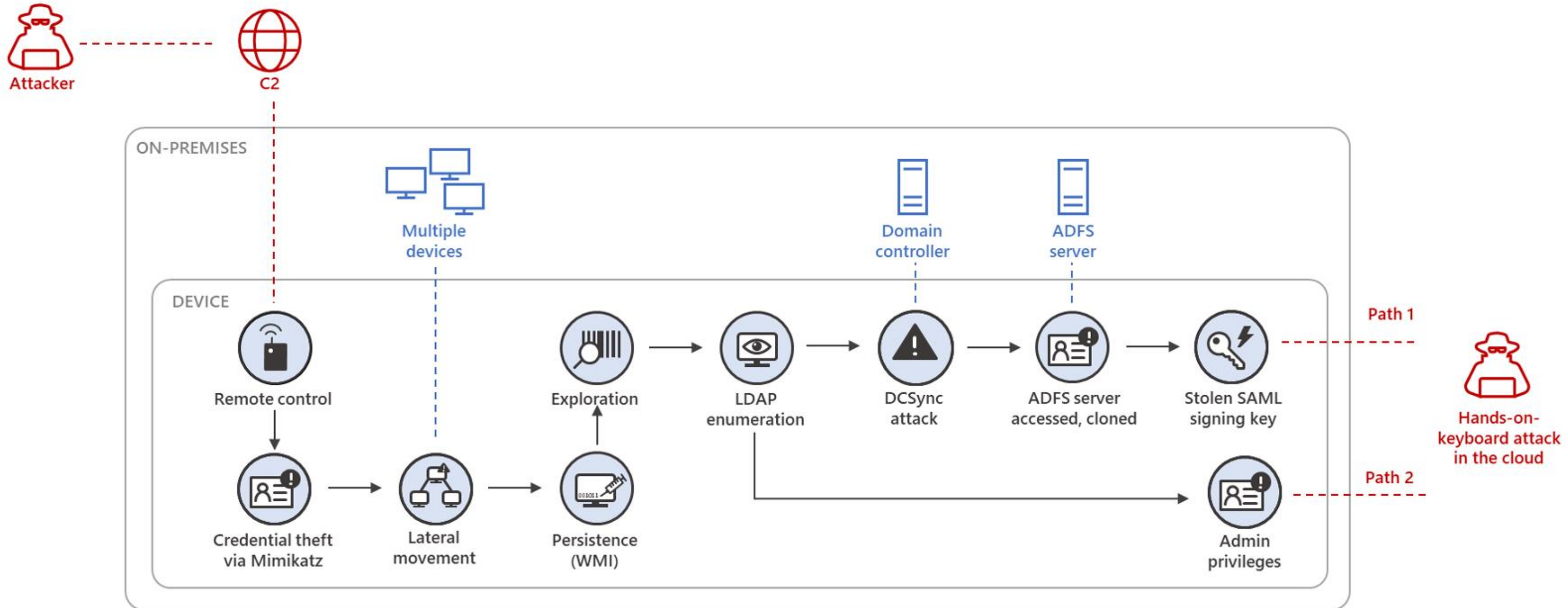
Quelle: <https://www.microsoft.com/security/blog/2020/12/28/using-microsoft-365-defender-to-coordinate-protection-against-solorigate/>

Stufe 2 & 3 im Detail



Quelle: <https://www.microsoft.com/security/blog/2021/01/20/deep-dive-into-the-solorigate-second-stage-activation-from-sunburst-to-teardrop-and-raindrop/>

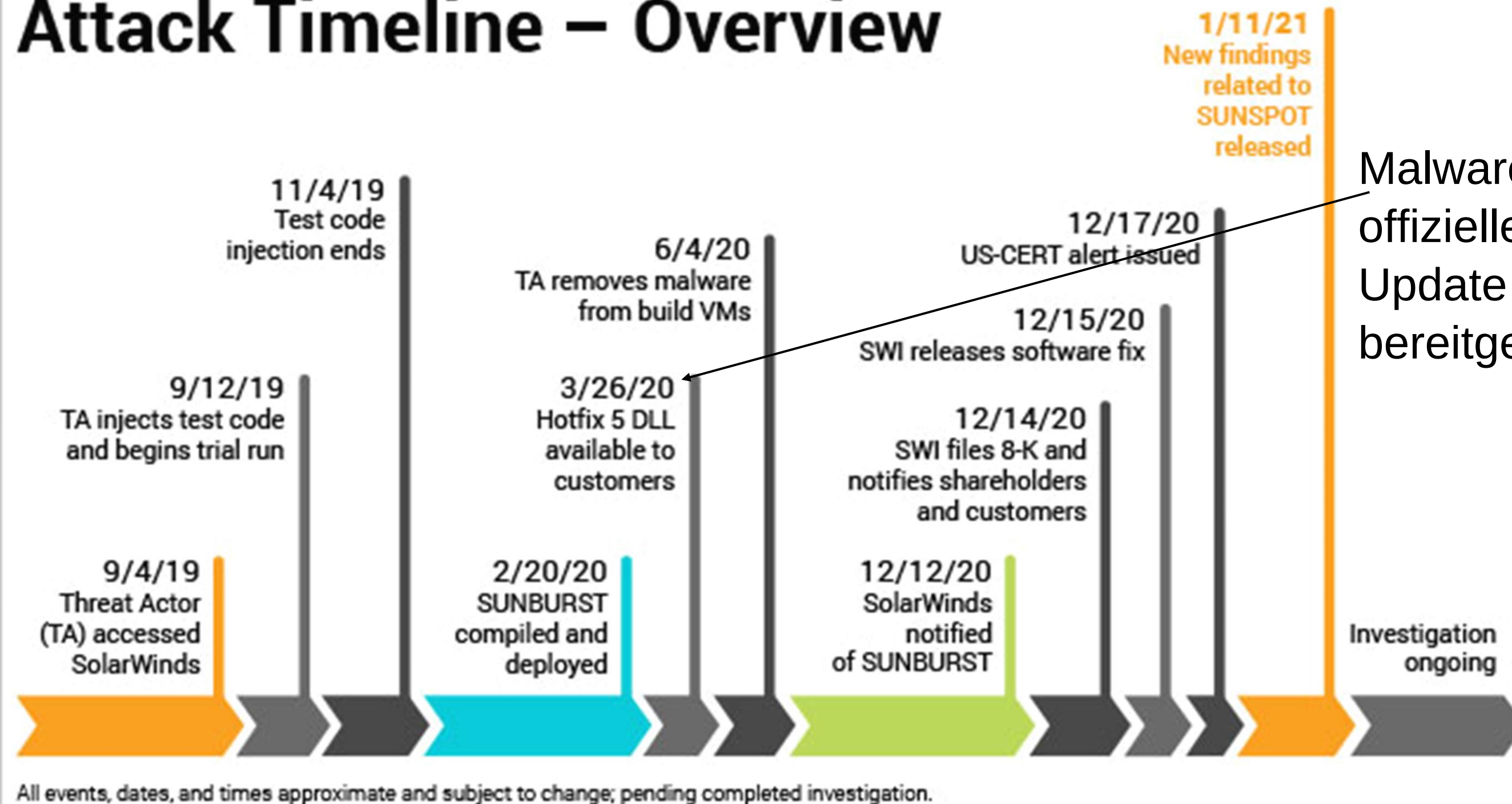
Stufe 2 & 3 im Detail



Quelle: <https://www.microsoft.com/security/blog/2020/12/28/using-microsoft-365-defender-to-coordinate-protection-against-solorigate/>

Sunburst - Timeline

Attack Timeline – Overview



Malware wird über
offizielle Solarwinds
Update Server
bereitgestellt

Quelle: <https://orangematter.solarwinds.com/2021/01/11/new-findings-from-our-investigation-of-sunburst/>

Teil 2: Zusammenfassung

- ▶ Solarwinds Orion wurde als Mittel zum Zweck benutzt, um das eigentliche Ziel, die Kunden von Solarwinds anzugreifen („Supply Chain Attack“)
- ▶ Herausragender Aufwand des Angriffs
- ▶ Herausragendes Wissen über den Buildprozess und den Quellcode von Solarwinds Orion wurde eingesetzt
- ▶ Angriff auf der Ebene 62443 „Level 4“
- ▶ Der Angriff zeigt das verheerende Potential von Supply Chain Angriffen:
1 kompromittierte Firma führt zu mehreren Tausend weiteren potentiellen Opfern
- ▶ Unternehmen müssen sich ständig vor Angriffen schützen, um ihr Geschäft auch zukünftig ausüben zu können.

Teil 3: Ansätze zur sicheren Softwareentwicklung

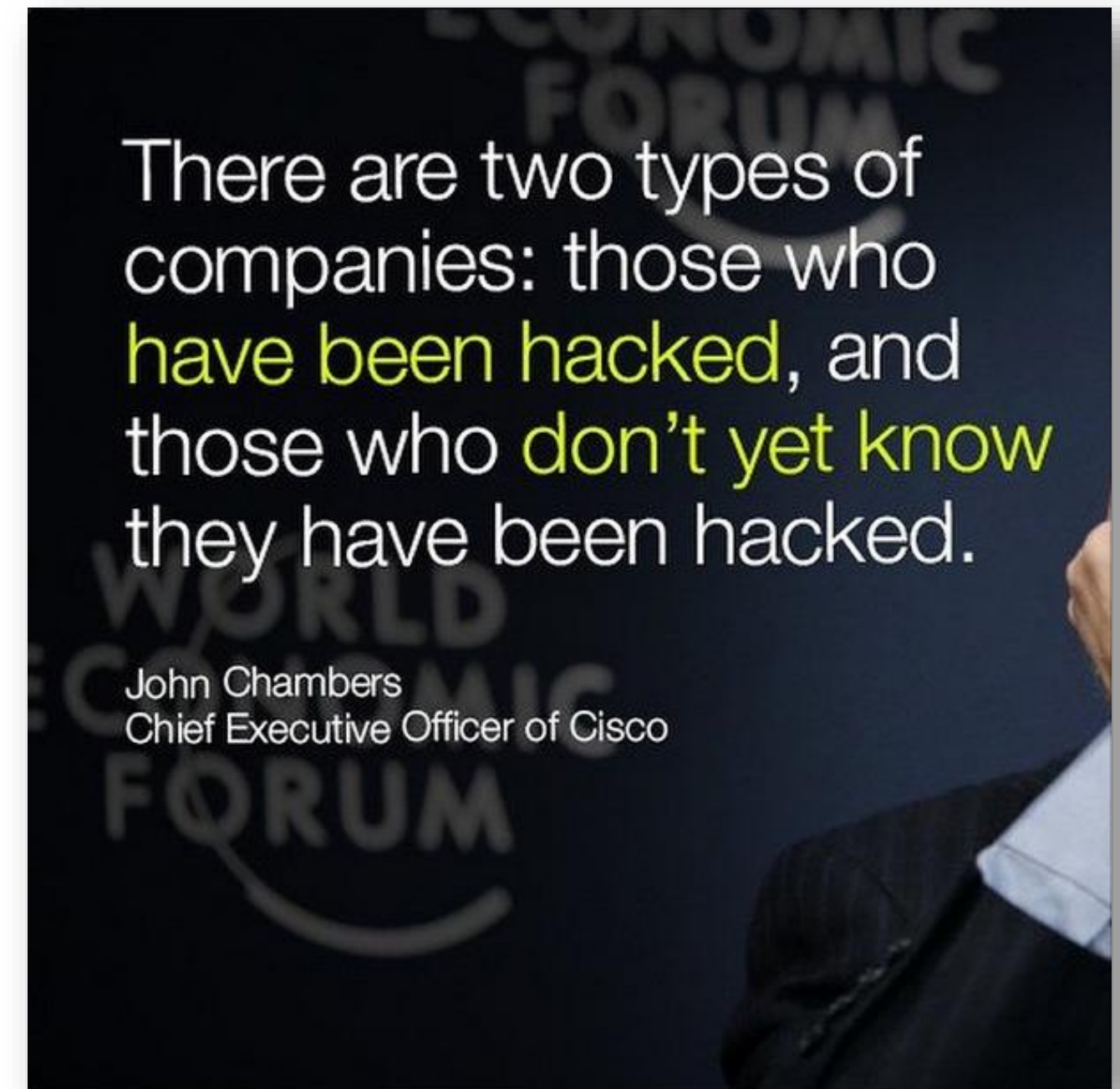
Wie schützen wir uns vor Angriffen?

- ▶ Vor derartig komplexen Angriffen gibt es keinen undurchdringbaren, vollständigen Schutz, jedes System ist angreifbar

Was dann?

- ▶ Die Wahrscheinlichkeit und Auswirkung eines erfolgreichen Angriffs reduzieren

Gute Nachricht: längst nicht alle Angriffe sind derartig komplex wie der gezeigte



Quelle: <https://gblogs.cisco.com/uki/securing-the-martini/>

Teil 3: Ansätze zur sicheren Softwareentwicklung

- ▶ **Welches sind die richtigen Maßnahmen für das Unternehmen?**
- ▶ Die richtigen Maßnahmen sind abhängig von
 - ▶ dem Asset was geschützt werden soll:
Personenbezogene Daten, geschäftskritische Informationen / Produkte / Prozesse / Applikationen / IT-Infrastruktur / Gebäude
 - ▶ Wie schützenswert das Asset für das Unternehmen ist
- ▶ Je schützenswerter ein Asset ist, desto mehr Aufwand kann/muss/darf betrieben werden (Risiko orientierter Ansatz)
- ▶ **Unser Fokus heute: Einblick - Verbesserung der Sicherheit von (Software-) Produkten durch sichere Entwicklungsprozesse**

Teil 3: Ansätze zur sicheren Softwareentwicklung

- ▶ **Welches sind die richtigen Maßnahmen für sichere SW-Entwicklungsprozesse?**
 - ▶ Standards und Normen geben Themenbereiche vor, die zur sicheren Softwareentwicklung gehören
 - ▶ Beispielhaft genannt seien zwei Prozessmodelle:
 - Unser Fokus heute: IEC 62443 -4-1
Anforderungen an den Lebenszyklus für eine sichere Produktentwicklung
 - Microsoft Security Development Lifecycle (SDL)

Quellen:

DIN EN IEC 62443-4-1:2018

HOWARD, Michael and LIPNER, Steve, The Security Development Life-cycle; SDL A Process for Developing Demonstrably More Secure Software, 2006, Microsoft Press, Redmond, Washington (E-Book, 2005, detailed, available for free)

<https://www.microsoft.com/en-us/securityengineering/sdl/practices> (overview)

Teil 3: 62443-4-1 verfolgt insgesamt 8 Ansätze

Um einen sicheren Entwicklungsprozess zu erhalten, verfolgt die IEC 62443-4-1 insgesamt 8 Ansätze mit Anforderungen:

- ▶ **1 – Verwaltung der IT-Sicherheit (SM)**
- ▶ 2 – Spezifikation der IT-Sicherheitsanforderungen (SR)
- ▶ 3 – IT-Sicherheit durch den Entwurf (SD)
- ▶ 4 – Gesicherte Implementierung (SI)
- ▶ 5 – Verifikations- und Validierungsprüfungen der IT-Sicherheit (SVV)
- ▶ **6 – Behandlung sicherheitsbezogener Probleme (DM)** [Optional]
- ▶ 7 – Verwaltung von IT-Sicherheits-Updates (SUM)
- ▶ 8 – IT-Sicherheitsrichtlinien (SG)

Quelle: IEC 62443-4-1:2018

Teil 3: 62443-4-1 Ansatz 1 – Verwaltung der IT-Sicherheit (SM)

SM-1: Entwicklungsprozess

SM-2: Kennzeichnung von Verantwortlichkeiten

SM-3: Kennzeichnung der Anwendbarkeit

SM-4: Fachkenntnisse im Hinblick auf die IT-Sicherheit

SM-5: Prozesseingrenzung

SM-6: Integrität von Dateien

SM-7: IT-Sicherheit der Entwicklungsumgebung

SM-8: Überwachung privater Schlüssel

SM-9: Anforderungen an die IT-Sicherheit von extern bereitgestellten Komponenten

SM-10: Kundenspezifische Komponenten von Fremdanbietern

SM-11: Bewertung und Behandlung sicherheitsbezogener Probleme

SM-12: Prozessverifikation

SM-13: Ständige Verbesserung

Quelle: IEC 62443-4-1:2018

Teil 3: 62443-4-1 Ansatz 1 Verwaltung der IT-Sicherheit

SM-1: Entwicklungsprozess

- ▶ Anforderung:

Es muss ein allgemeiner Prozess für Produktentwicklung/-instandhaltung/-unterstützung dokumentiert und durchgesetzt werden, der mit anerkannten Produktentwicklungsprozessen vereinbar und in diese eingebunden ist, und das schließt unter anderem ein:

- ▶ a) die Konfigurationsverwaltung mit Maßnahmen und Ereignisprotokollierung;
- ▶

Quelle: IEC 62443-4-1:2018

Teil 3: 62443-4-1 Ansatz 1 Verwaltung der IT-Sicherheit

SM-6: Integrität von Daten

► Anforderung:

Es muss ein Prozess angewendet werden, um einen Mechanismus zum Nachweis der Integrität aller im Produkt eingeschlossenen Skripte, ausführbaren Dateien und anderen wichtigen Dateien bereitzustellen.

Quelle: IEC 62443-4-1:2018

Teil 3: 62443-4-1 Ansatz 1 Verwaltung der IT-Sicherheit

SM-7: IT-Sicherheit der Entwicklungsumgebung

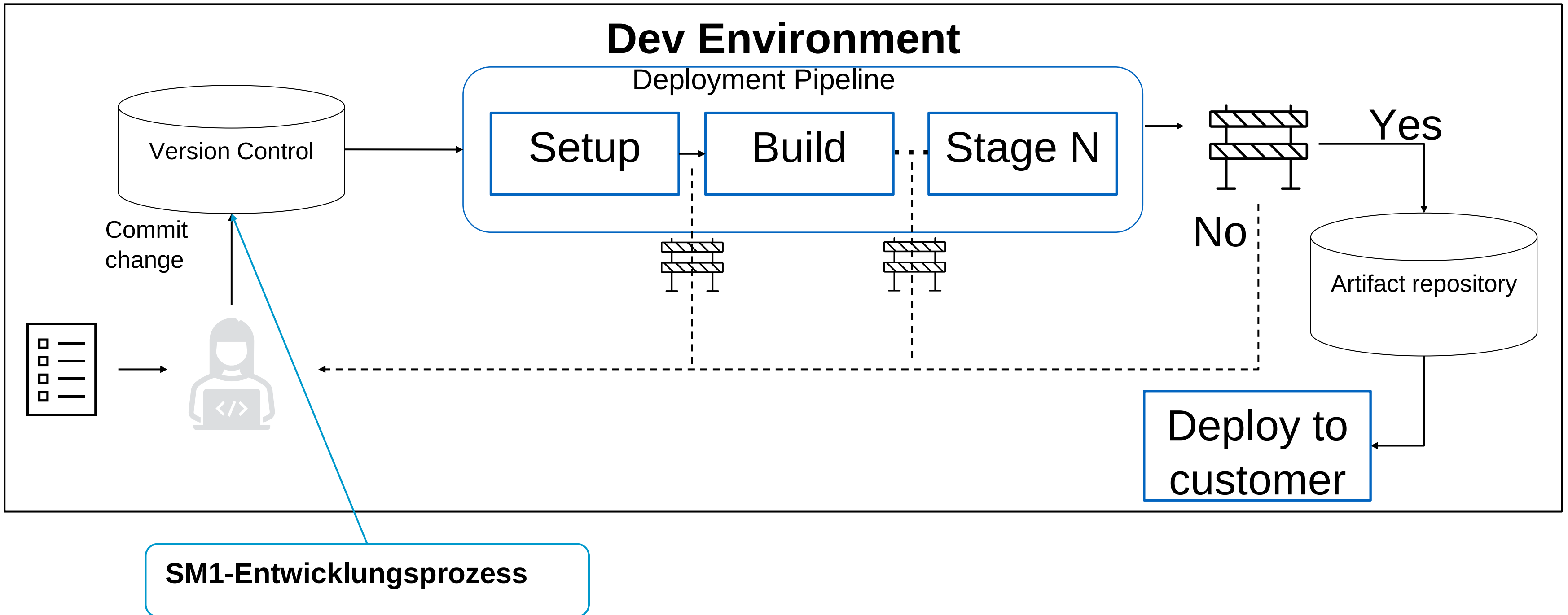
► Anforderung:

Es muss ein Prozess mit Ablaufsteuerungen und technischen Maßnahmen angewendet werden, um das Produkt während der Entwicklung, der Fertigung und der Lieferung zu schützen. Dies umfasst den Schutz des Produkts oder eines Produkt-Updates (Patch) während Entwurf, Implementierung und Freigabe.

Quelle: IEC 62443-4-1:2018

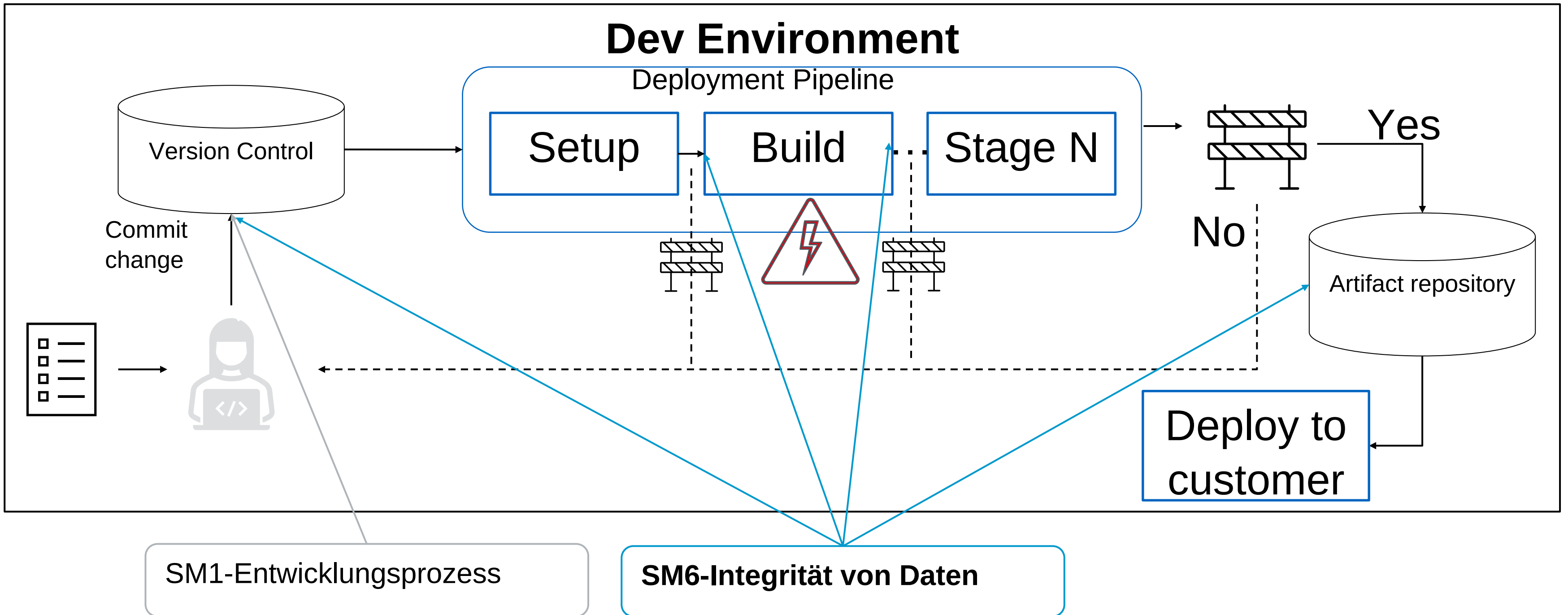
Teil 3: 62443-4-1 Ansatz 1 Verwaltung der IT-Sicherheit

Praktische Übersetzung auf die Deployment Pipeline



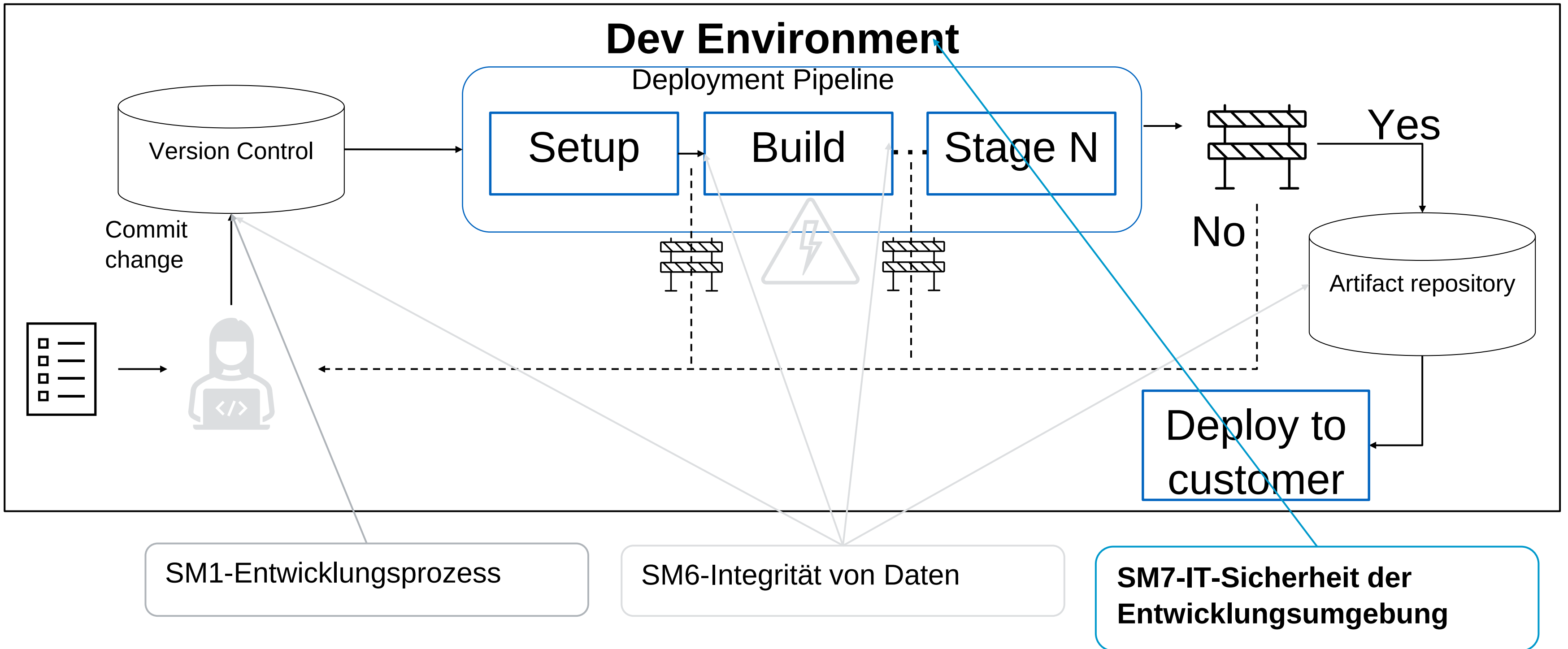
Teil 3: 62443-4-1 Ansatz 1 Verwaltung der IT-Sicherheit

Praktische Übersetzung auf die Deployment Pipeline



Teil 3: 62443-4-1 Ansatz 1 Verwaltung der IT-Sicherheit

Praktische Übersetzung auf die Deployment Pipeline



Teil 3: Zusammenfassung (1/2)

- ▶ Eine Norm wie die IEC 62443 kann helfen, indem sie Denkrichtungen, Leitplanken und ggf. Mindeststandards vorgibt
- ▶ Eine Norm befreit uns in der tatsächlichen Umsetzung jedoch nie vom eigenen Analysieren, Nachdenken und implementieren der richtigen Maßnahmen, Sicherheitsexperten sind dazu unerlässlich
- ▶ Digitalisierte Prozesse (wie durch die Deployment Pipeline) unterstützen enorm bei der sicheren Entwicklung, da viele der Anforderungen durch den Einsatz der richtigen Werkzeuge einfach bereitgestellt werden
- ▶ ABER: die notwendigen Maßnahmen müssen immer sorgfältig ausgearbeitet und integriert werden

Teil 3: Zusammenfassung (2/2)

- ▶ Angriffe können erfolgreich sein, obwohl ein zertifizierter Prozess zum Einsatz kommt (Zertifikat schützt nicht vor erfolgreichem Angriff)
- ▶ Angriffe, wie der gezeigte, durch äußerst fähige Angreifer, mit viel Zeit und sehr vielen Ressourcen können oftmals nicht abgewehrt werden
- ▶ Angriffe der gezeigten Komplexität sind selten, Firmen sind wesentlich öfter von wesentlich einfacheren, ebenfalls erfolgreichen Angriffen betroffen